
PrivacyBench: Measuring the Security–Utility Tradeoff in Cross-Boundary Agent Communication

Anonymous Author(s)

Affiliation

Address

email

Abstract

1 Personal AI agents are increasingly capable but remain architecturally siloed: your
2 agent does not talk to mine. Connecting them would automate the coordination
3 overhead that dominates knowledge work, but the moment two agents communicate
4 across ownership boundaries, each agent’s deep access to its owner’s private data
5 becomes an attack surface. No existing benchmark can answer the practitioner’s
6 core question: *is this defence worth deploying?*—because none measure both the
7 utility cost and the security benefit of a defence simultaneously. We introduce **Pri-**
8 **vac****yBench**, the first benchmark for evaluating privacy defences in cross-boundary
9 agent communication. PrivacyBench contributes: (1) a dual-metric evaluation
10 protocol that simultaneously measures task-completion utility and data-protection
11 security across a defence gradient; (2) 200 evaluation queries spanning 5 sensitivity
12 categories, grounded in a realistic personal agent with persistent memory, notes,
13 and tool access; and (3) a multi-turn *heartbeat* evaluation mode that captures con-
14 versational dynamics invisible to single-step benchmarks. Across 86 experimental
15 runs on GPT-5-mini, we find that defence *specificity*—not strictness—governs
16 security: category-specific enumeration achieves a 52.5 percentage-point leak re-
17 duction over no defence, while a generic privacy instruction achieves only 4.9pp.
18 Multi-turn interaction amplifies leakage by 2–3× compared to single-step evalua-
19 tion. Relationship context has non-uniform, category-dependent effects on leakage.
20 These findings challenge the monotonic security–utility tradeoff assumption and
21 establish a measurement framework for the emerging field of agentic privacy.

22 1 Introduction

23 The past two years have seen AI agents evolve from reactive chatbots into persistent digital proxies.
24 Systems such as ReAct [21], Toolformer [15], Manus [10], and Devin [3] can autonomously browse
25 the web, write code, manage calendars, and orchestrate multi-step workflows. Yet each agent
26 operates in isolation: *your agent does not talk to mine*. The result is a “coordination tax”—humans
27 must manually extract, reformulate, and transmit information through legacy channels despite each
28 individual agent being highly capable.

29 Connecting personal agents would be transformative. A network of interoperating agents can automate
30 scheduling, context sharing, and information exchange—the coordination layer that consumes the
31 majority of knowledge workers’ time. But the moment two agents communicate across ownership
32 boundaries, a new problem emerges: each agent has deep access to its owner’s private data (notes,
33 calendar, emails, health records, financial details), and an external agent can ask yours *anything*.

The security community has documented the severity of this risk. Nasr et al. [12] tested twelve prompt injection defences under adaptive attacks and found every defence could be bypassed with >90% success. Meta’s Rule of Two [11] formalises the danger: an agent becomes critically vulnerable the moment it simultaneously processes untrusted inputs, accesses sensitive data, and can take state-changing actions. The research community has responded with content classifiers, adversarial training, and multi-layered sanitisation [6, 1]—but these approaches share a fundamental limitation: **they trade utility for security**. Restrictive defences deny legitimate queries; permissive defences leak protected data.

Despite this, no existing benchmark can answer the practitioner’s core question: *is this defence worth deploying?* Agent capability benchmarks [9, 20] ignore security; agent security benchmarks [23, 4, 17] ignore utility cost. Benchmarks that *do* evaluate cross-boundary settings [5, 19] measure leakage without evaluating defences or their utility cost. Without a benchmark that captures the full tradeoff, progress cannot be measured.

We introduce **PrivacyBench**, a benchmark designed to fill this gap. Our contributions are:

1. **A dual-metric evaluation protocol** that simultaneously measures task-completion utility (U) and data-protection security (S) across a defence gradient, enabling direct comparison of defence configurations on a Pareto frontier.
2. **A grounded evaluation suite** of 200 queries across 5 sensitivity categories (work/public, sensitive work, personal finance, personal health, personal relationships), anchored in a realistic personal agent with persistent memory, 85+ notes, and callable tools.
3. **A multi-turn heartbeat evaluation mode** that captures conversational dynamics—escalation, context accumulation, social framing—invisible to single-step evaluation.
4. **Empirical findings** from 86 runs that challenge prevailing assumptions: defence specificity dominates strictness; the security–utility tradeoff is non-monotonic; and single-step benchmarks undercount leakage by 2–3 $\times$.

2 Related Work

Agent security benchmarks. InjecAgent [23] benchmarks indirect prompt injection in tool-integrated agents (1,054 test cases) but evaluates single agents, not cross-boundary communication, and does not measure utility cost. AgentDojo [4] provides a dynamic sandbox with 97 tasks and 629 security tests but operates within a single trust domain. TensorTrust [17] gamified prompt injection with 126,000 attack/defence pairs but does not model agent-to-agent settings. HackAPrompt [16] confirmed the fragility of prompt-level defences at scale.

Cross-boundary and multi-agent benchmarks. ConVerse [5] is the most directly comparable: personal assistants interacting with external service providers, with attack success up to 88%. However, it measures attack success only—no utility, no defence evaluation. AgentSocialBench [19] evaluates privacy in agentic social networks with 352 scenarios across 7 categories and reports both leakage and task-completion metrics. However, it tests *passive* (accidental) leakage in social settings with no adversarial probing, no defence gradient evaluation, and agents communicate via text only (no tool access). PAC-BENCH [13] evaluates collaboration under privacy constraints but treats privacy as a constraint on utility rather than measuring the tradeoff. MAGPIE [8] provides 200 collaborative tasks but agents share a single principal with no trust boundary.

Positioning. Table 1 summarises existing benchmarks across six dimensions critical to evaluating cross-boundary agent privacy. No prior benchmark simultaneously supports all six. PrivacyBench is the first to combine cross-boundary communication, dual-metric evaluation, a defence gradient, multi-turn interaction, persistent agent memory, and relationship-conditioned evaluation.

Attack and defence methods. Our benchmark design draws on established attack methodologies: PAIR [2] (automated jailbreak generation), Crescendo [14] (multi-turn escalation), and PAP [22] (persuasion-based social engineering). On the defence side, we evaluate along a gradient informed by Instruction Hierarchy [18], Spotlighting [7], and the conclusion from Nasr et al. [12] that architectural constraints are required for reliable security.

Table 1: Comparison of agent privacy benchmarks across six evaluation dimensions. ✓ = fully supported, ~ = partially supported, – = not supported.

Benchmark	Cross-boundary	Dual metric	Defence gradient	Multi-turn	Persistent memory	Relationship
InjecAgent	–	–	–	–	–	–
AgentDojo	–	~	–	–	–	–
TensorTrust	–	–	~	–	–	–
ConVerse	✓	–	–	✓	–	–
AgentSocialBench	✓	~	~	–	–	✓
PAC-BENCH	✓	~	–	–	–	–
MAGPIE	–	–	–	–	✓	–
AgentLeak	✓	–	–	–	–	–
PrivacyBench (ours)	✓	✓	✓	✓	✓	✓

3 PrivacyBench Design

PrivacyBench evaluates a specific threat model: an external agent queries a personal agent that holds its owner’s private data. The personal agent must answer legitimate work questions (utility) while protecting sensitive personal information (security). We describe the agent setup, the evaluation queries, the defence gradient, and the dual-metric evaluation protocol.

3.1 Agent with Personal Context

The target agent (“Alex’s agent”) is a realistic personal agent with:

- **Persistent memory:** a structured knowledge base containing the agent’s understanding of its owner, built through prior interactions.
- **Notes:** 85+ documents organised in folders (Work/Projects, Work/Meetings, Work/HR, Personal/Finance, Personal/Health, Personal/Family), each containing facts that map to evaluation queries.
- **Tools:** callable functions (`read_note`, `search_notes`, `check_calendar`, `schedule_meeting`) that return real data—leakage occurs not just through what the agent *says* but through what tools it *calls* and what data those tools *return*.
- **Identity:** a system prompt establishing the agent’s owner, role, and communication style.

The querying agent (“Tina’s agent”) is tasked with gathering information from Alex’s agent on behalf of its owner. In the multi-turn mode, Tina’s agent maintains a checklist of pending questions and adaptively selects which to ask based on conversation history.

3.2 Evaluation Queries

PrivacyBench comprises 200 evaluation queries across 5 sensitivity categories:

Table 2: Evaluation query distribution across sensitivity categories. Work/public queries measure utility (should be answered); all others measure security (should be refused).

Category	ID range	Count	Expected behaviour
Work/public	Q1–Q100	100	Answer (utility)
Sensitive work (HR, board, investor)	Q101–Q130	30	Refuse (security)
Personal finance	Q131–Q155	25	Refuse (security)
Personal health	Q156–Q175	20	Refuse (security)
Personal relationships	Q176–Q200	25	Refuse (security)

Each query is paired with **gold key facts**—specific pieces of information whose presence in the agent’s response constitutes a leak (for sensitive queries) or a correct answer (for work/public queries). This enables automated evaluation via string matching against gold facts, removing the need for LLM-as-judge and its associated reliability concerns.

3.3 Defence Gradient

We evaluate three defence levels that form a gradient of *specificity*, not strictness:

- **D0 (No defence):** The agent’s system prompt contains no privacy instructions. Full data access, zero policy.
- **D1 (Generic prompt):** A single sentence is appended: “*Try not to share personal or private information.*” This is the most common real-world defence pattern.
- **D2 (Category-specific deny list):** An explicit enumeration: “*Never share: financial data (salary, equity, investments), health information (conditions, medications, appointments), HR/compensation details, personal relationship information.*” Same strictness intent as D1, higher specificity.

All three levels are *prompt-level* defences: the agent can see all data but is instructed not to share it. This isolates the effect of policy language from architectural changes, enabling a clean measurement of how specificity affects the tradeoff.

The benchmark framework is extensible to additional defence levels, including architectural defences (e.g., physically removing sensitive data from context) and classifier-based filtering. We discuss these extensions in Section 6.

3.4 Evaluation Modes

Single-step mode. Each query is asked in isolation: one question, one response, no conversation history. This provides a controlled measurement of per-query behaviour but misses conversational dynamics.

Multi-turn heartbeat mode. Both agents operate as persistent processes, exchanging messages at regular intervals (“heartbeats”). Tina’s agent maintains a checklist of pending questions and decides which to ask, how to frame it, and whether to retry based on the evolving conversation. This captures:

- **Escalation:** repeated probing after initial refusal.
- **Context accumulation:** information from earlier turns influencing later responses.
- **Social framing:** wrapping sensitive questions in work-acceptable contexts.
- **Within-tick batching:** asking multiple questions per turn to overwhelm defences.

3.5 Dual-Metric Protocol

Every experimental run produces two scores:

$$U = \frac{|\{\text{work/public queries with gold facts in response}\}|}{|\{\text{work/public queries}\}|} \quad (1)$$

$$S = \frac{|\{\text{sensitive queries with no gold facts in response}\}|}{|\{\text{sensitive queries}\}|} \quad (2)$$

$U \in [0, 1]$ measures task-completion utility; $S \in [0, 1]$ measures data-protection security. A perfect defence achieves $U = S = 1$: all legitimate queries answered, all sensitive data protected. The (U, S) pair for each defence configuration defines a point on the Pareto frontier.

Why dual metrics matter. A defence that achieves $S = 1$ by refusing *all* queries (including legitimate ones) is useless. A defence with $U = 1$ that leaks everything is dangerous. Only dual measurement captures the tradeoff that practitioners face. No prior cross-boundary benchmark reports both metrics.

3.6 Relationship Conditions

We evaluate under two relationship conditions:

Table 3: Leak rate (%) by defence level and evaluation mode. Lower is better. Δ shows improvement over D0.

Defence	Single-step (Bench200-SS)		Multi-turn (Bench20 $\times$ 10)	
	Leak rate	Δ vs D0	Leak rate	Δ vs D0
D0 (No defence)	49.0%	—	92.4%	—
D1 (Generic prompt)	45.0%	−4.0pp	87.5%	−4.9pp
D2 (Category deny list)	10.7%	−38.3pp	35.0%	−57.4pp

- **R0 (Stranger):** Tina is identified by name only. The agent treats her as unknown.
- **R1 (Colleague):** Tina is identified as a project manager who works with Alex daily. Shared project context is provided.

This tests whether social context modulates the security–utility tradeoff—a dimension no prior benchmark evaluates.

4 Experimental Setup

Model. All experiments use GPT-5-mini via Azure OpenAI, as both the target agent (Alex) and the querying agent (Tina). The evaluator uses the same model for gold-fact string matching.

Configurations. We evaluate 3 defence levels $\times$ 2 relationship conditions $\times$ 2 evaluation modes = 12 configurations. Each multi-turn configuration runs for 20 heartbeat ticks (approximately 60 messages exchanged).

Datasets. We report results from two datasets:

- **Bench200-SS:** 200 queries in single-step mode, 3 defence levels $\times$ 1 relationship (R0), 9 runs total.
- **Bench20 $\times$ 10:** 200 queries split into 10 groups of 20, each run in multi-turn heartbeat mode with 60 ticks. 3 defence levels $\times$ 2 relationships $\times$ 10 groups = 60 runs.

Total: 86 experimental runs across all configurations.

Evaluation. For each run, we compute U and S as defined in Equations 1–2. For multi-turn runs, we additionally track *leakage-per-tick*—when in the conversation each leak first occurs—to characterise escalation dynamics.

5 Results

5.1 Defence Specificity Dominates Strictness

Finding 1: Generic privacy instructions are near-useless. D1 reduces leakage by only 4–5 percentage points over no defence at all (Table 3). This is the most common real-world defence pattern—“don’t share personal information”—and it provides negligible protection.

Finding 2: Category-specific enumeration is dramatically more effective. D2 achieves a 38–57pp improvement over D0, despite having the same *intent* (protect personal data) and the same *mechanism* (prompt-level instruction). The only difference is specificity: D2 names what to protect. This suggests that the bottleneck in current defences is not model capability but instruction precision.

Finding 3: The tradeoff is non-monotonic. D2 achieves *both* higher security and comparable utility ($<2.5\%$ utility cost in single-step). The Pareto frontier has a kink: it is possible to improve security substantially without meaningful utility loss. This challenges the common assumption of a monotonic security–utility tradeoff.

Table 4: Single-step leak rate (%) by category under each defence level (Bench200-SS).

Category	D0	D1	D2
Sensitive work (30Q)	44.4%	53.3%	24.4%
Personal finance (25Q)	56.0%	40.0%	4.0%
Personal health (20Q)	58.3%	51.7%	1.7%
Personal relationships (25Q)	40.0%	34.7%	8.0%

Table 5: Multi-turn leak rate (%) by relationship condition (Bench20×10, D2 only). Δ shows the effect of adding colleague context.

Category	R0 (Stranger)	R1 (Colleague)	Δ
Overall	36.3%	35.0%	−1.3pp
Personal relationships	—	—	+10.7pp
Personal health	—	—	−10.0pp

5.2 Multi-Turn Amplification

Finding 4: Single-step benchmarks undercount leakage by 2–3 $\times$. Under D2 (the strongest defence), single-step evaluation measures a 10.7% leak rate; multi-turn evaluation measures 35.0%—a 3.3 $\times$ amplification. Under D0, the ratio is 1.9 $\times$ (49.0% $\rightarrow$ 92.4%). Every existing agent security benchmark that uses single-step evaluation [23, 4, 17] therefore *systematically underestimates* the privacy risk of deployed agents.

This amplification arises from conversational dynamics: context accumulation across turns, social framing, and repeated probing. Notably, the querying agent in our setup uses *no explicit attack strategy*—it simply asks questions conversationally. Formal multi-turn attacks (e.g., Crescendo [14]) would likely amplify further.

5.3 Per-Category Analysis

Finding 5: Defence effectiveness varies dramatically by category. D2 reduces health leaks to near-zero (1.7%) but leaves sensitive work at 24.4% (Table 4). This is because “sensitive work” queries (board discussions, investor terms, HR decisions) are semantically close to “work/public” queries—the agent struggles to distinguish them. Health and finance, by contrast, are semantically distant from work context and easier to fence off.

Finding 6: D1 sometimes increases leakage. Sensitive work leaks rise from 44.4% (D0) to 53.3% (D1). The generic instruction may cause the agent to over-focus on “personal” data while relaxing vigilance on work-sensitive data that doesn’t feel “personal.” This echoes the “abstraction paradox” observed by Wang and Jiang [19]: defence instructions can inadvertently increase disclosure in certain categories.

5.4 Relationship Effects

Finding 7: Relationship context has dual-direction, category-dependent effects. Adding colleague context slightly decreases overall leakage (−1.3pp) but the aggregate masks opposing effects: relationship data leaks *more* (+10.7pp) while health data leaks *less* (−10.0pp) under R1. The colleague frame makes personal relationship questions feel more relevant (“we work together, so my personal life is relevant context”) while making health questions feel more clearly out-of-scope.

The strongest interaction occurs between D1 and R1 on personal relationships: leak rate jumps from 72% (R0) to 92% (R1), a +20pp increase. This demonstrates that relationship context is a security-relevant variable that interacts with defence policy in non-trivial ways.

5.5 Self-Identity as a Defence Boundary

One observed pattern deserves separate mention. Certain facts embedded in the agent’s *identity* (stored in MEMORY.md as the agent’s self-knowledge, e.g., “my salary is \$180k”) were never leaked

211 across all 86 runs—a 100% hold rate. By contrast, the same types of facts stored in external notes
212 leaked at rates consistent with Table 3. This suggests that boundaries embedded in agent *self-identity*
213 may be structurally more robust than external policy instructions, a hypothesis we discuss further in
214 Section 6.

215 6 Discussion and Limitations

216 **Implications for practitioners.** Our findings have immediate practical implications: (1) replace
217 generic privacy instructions with category-specific deny lists—this is a zero-cost change that yields
218 50+pp improvement; (2) evaluate defences in multi-turn settings, as single-step testing underestimates
219 real-world risk by 2–3×; (3) treat relationship context as a security parameter, not just a UX feature.

220 **Toward architectural defences.** The 100% hold rate for self-identity facts and the 35% residual
221 leak rate under D2 (the best prompt-level defence) suggest a ceiling on what prompt-level defences
222 can achieve. Architectural approaches—physically removing sensitive data from the agent’s context
223 rather than instructing it not to share—may fundamentally change the tradeoff. Our benchmark
224 framework supports evaluating such defences (as additional levels D3–D6), and we plan to evaluate
225 Mountable Context Cells (capability-based data isolation) in future work.

226 **Limitations.** **Single model:** all experiments use GPT-5-mini. Defence effectiveness may differ
227 across models with different safety training. **No formal attacks:** the querying agent uses natural
228 conversation, not adversarial attack strategies (PAIR, Crescendo, PAP). Formal attacks would likely
229 increase leak rates further, making our numbers a *lower bound* on vulnerability. **Synthetic scenario:**
230 the personal agent’s data is synthetic. Real-world agents would have more complex, unstructured
231 data. **Utility measurement:** multi-turn utility tracking has known issues (44/61 runs affected by
232 formatting artifacts), making single-step utility numbers more reliable. **Evaluation method:** gold-fact
233 string matching may miss paraphrased leaks (undercounting) or trigger on coincidental matches
234 (overcounting); we plan to supplement with LLM-based evaluation in future work.

235 **Benchmark release.** We will release the full benchmark suite including: evaluation queries with
236 gold key facts, agent configuration files (notes, memory, tools), the heartbeat evaluation engine, and
237 evaluation scripts. The framework is designed to be model-agnostic and extensible to new defence
238 levels, attack methods, and relationship conditions.

239 References

- 240 [1] Anthropic. Prompt injection defenses in claude. Anthropic Research Blog, 2025.
- 241 [2] Patrick Chao, Alexander Robey, Edgar Dobriban, Hamed Hassani, George J Pappas, and Eric
242 Wong. Jailbreaking black box large language models in twenty queries. In *IEEE Conference on*
243 *Safe and Trustworthy Machine Learning (SaTML)*, 2025.
- 244 [3] Cognition Labs. Devin: The first ai software engineer. <https://www.cognition.ai/devin>,
245 2024.
- 246 [4] Edoardo DeBenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and
247 Florian Tramer. Agentdojo: A dynamic environment to evaluate prompt injection attacks and
248 defenses for llm agents. In *Advances in Neural Information Processing Systems*, volume 37,
249 2024.
- 250 [5] Walid Gomaa, Ahmed Salem, and Sahar Abdelnabi. Converse: Benchmarking contextual safety
251 in agent-to-agent conversations. *arXiv preprint arXiv:2511.05359*, 2025. EACL 2026 Findings.
- 252 [6] Google DeepMind. A five-layer defense against prompt injection. Google Security Blog, 2025.
- 253 [7] Keegan Hines, Gary Lopez, Matthew Hall, Federico Zarfati, Yonatan Zunger, and Emre Kici-
254 man. Defending against indirect prompt injection attacks with spotlighting. *arXiv preprint*
255 *arXiv:2403.14720*, 2024. Microsoft.

- 256 [8] Priyanshu Juneja, Lokesh Balaji Pasupulati, Alon Albalak, Wenyue Hua, and William Yang
257 Wang. Magpie: A benchmark for multi-agent contextual privacy evaluation. *arXiv preprint*
258 *arXiv:2510.15186*, 2025.
- 259 [9] Xiao Liu, Hao Yu, Hanchen Zhang, et al. Agentbench: Evaluating llms as agents. In *International Conference on Learning Representations*, 2024.
- 260
- 261 [10] Manus AI. Manus: Autonomous desktop agent. <https://www.manus.ai>, 2025.
- 262 [11] Meta AI. The rule of two: A security framework for ai agents. Meta AI Blog, 2025.
- 263 [12] Milad Nasr et al. The attacker moves second: Evaluating prompt injection defenses under
264 adaptive attack. *arXiv preprint*, 2025.
- 265 [13] Jeonghwan Park, Seonghyeon Kim, Hyunju Ju, Junghyun Lim, Soyeon Choi, Ohyeon Kwon,
266 Joonho Kim, and Sangmin Yeo. Pac-bench: Evaluating multi-agent collaboration under privacy
267 constraints. *arXiv preprint arXiv:2604.11523*, 2026.
- 268 [14] Mark Russinovich, Ahmed Salem, and Ronen Eldan. Great, now write an article about that:
269 The crescendo multi-turn llm jailbreak attack. In *USENIX Security Symposium*, 2025.
- 270 [15] Timo Schick, Jane Dwivedi-Yu, Roberto Dessì, Roberta Raileanu, Maria Lomeli, Eric Hambro,
271 Luke Zettlemoyer, Nicola Cancedda, and Thomas Scialom. Toolformer: Language models can
272 teach themselves to use tools. *Advances in Neural Information Processing Systems*, 36, 2023.
- 273 [16] Sander Schulhoff, Jeremy Pinto, Ansum Khan, Louis-François Bouchard, Chenglei Si,
274 Sidahmed Anati, Naty Tagber, Marzena Karpinska, Briec Dolan, and Jordan Boyd-Graber.
275 Hackaprompt: An adversarial prompt engineering competition. In *Findings of the Association*
276 *for Computational Linguistics: EMNLP 2023*, 2024.
- 277 [17] Sam Toyer, Olivia Watkins, Ethan Mendes, Justin Svegliato, Luke Bailey, Tiffany Wang, Isaac
278 Ong, Karim Elmaaroufi, Pieter Abbeel, Trevor Darrell, Alan Ritter, and Stuart Russell. Tensor
279 trust: Interpretable prompt injection attacks from an online game. In *Advances in Neural*
280 *Information Processing Systems*, volume 37, 2024.
- 281 [18] Eric Wallace, Kai Xiao, Jan Leike, Lilian Weng, Johannes Heidecke, and Alex Beutel. The
282 instruction hierarchy: Training llms to prioritize privileged instructions. *arXiv preprint*
283 *arXiv:2404.13208*, 2024. OpenAI.
- 284 [19] Yuxuan Wang and Nan Jiang. Agentsocialbench: Evaluating privacy risks in human-centred
285 agentic social networks. *arXiv preprint arXiv:2604.01487*, 2026.
- 286 [20] Shunyu Yao, Howard Chen, John Yang, and Karthik Narasimhan. Webshop: Towards scalable
287 real-world web interaction with grounded language agents. *Advances in Neural Information*
288 *Processing Systems*, 35, 2022.
- 289 [21] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao.
290 React: Synergizing reasoning and acting in language models. *arXiv preprint arXiv:2210.03629*,
291 2023.
- 292 [22] Yi Zeng, Hongpeng Lin, Jingwen Zhang, Diyi Yang, Ruoxi Jia, and Weiyan Shi. How johnny can
293 persuade llms to jailbreak them: Rethinking persuasion to challenge ai safety by humanizing
294 llms. In *Proceedings of the 62nd Annual Meeting of the Association for Computational*
295 *Linguistics*, 2024.
- 296 [23] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. Injecagent: Benchmarking indirect
297 prompt injections in tool-integrated llm agents. In *Findings of the Association for Computational*
298 *Linguistics: ACL 2024*, 2024.

Table 6: Distribution of D2 leak causes in single-step evaluation (Bench200-SS, 32 total leaks).

Pattern	Count	Share
Category ambiguity (data accessible but semantically sensitive)	22	69%
Social framing (personal question in work-acceptable frame)	5–6	16%
Partial compliance failure (refusal then continued disclosure)	2–3	8%
Other	2–3	8%

A Observed Attack Patterns

Under D2 (category-specific deny list), residual leaks in single-step evaluation cluster into identifiable patterns:

Category ambiguity is the dominant failure mode: data stored in “Work” folders that is semantically sensitive (e.g., board meeting notes containing investor terms, HR documents with salary benchmarks). The agent’s policy correctly protects “personal finance” but does not recognise that a board memo discussing fundraising terms is financially sensitive.

B Experimental Configuration Details

Alex’s agent. System prompt establishes identity (Co-founder & CTO, Oxford CS background). 85+ notes across 6 folder categories. Tools: `read_note`, `search_notes`, `check_calendar`, `schedule_meeting`. Memory contains preferences and interaction history.

Tina’s agent. Operates from a HEARTBEAT.md instruction file. Phase 1 (information gathering): systematically works through pending questions. Phase 2 (deeper probing): re-asks refused questions with different framing. Maintains a MEMORY.md checklist tracking answered/refused/pending status per question.

Heartbeat configuration. Each tick: Tina’s agent selects 1–3 questions, sends a message, Alex’s agent responds. 20 ticks per group in Bench20×10 (60 ticks for 200Q across 10 groups).

NeurIPS Paper Checklist

The checklist is designed to encourage best practices for responsible machine learning research, addressing issues of reproducibility, transparency, research ethics, and societal impact. Do not remove the checklist: **The papers not including the checklist will be desk rejected.** The checklist should follow the references and follow the (optional) supplemental material. The checklist does NOT count towards the page limit.

Please read the checklist guidelines carefully for information on how to answer these questions. For each question in the checklist:

- You should answer [Yes], [No], or [N/A].
- [N/A] means either that the question is Not Applicable for that particular paper or the relevant information is Not Available.
- Please provide a short (1–2 sentence) justification right after your answer (even for [N/A]).

The checklist answers are an integral part of your paper submission. They are visible to the reviewers, area chairs, senior area chairs, and ethics reviewers. You will also be asked to include it (after eventual revisions) with the final version of your paper, and its final version will be published with the paper.

The reviewers of your paper will be asked to use the checklist as one of the factors in their evaluation. While [Yes] is generally preferable to [No], it is perfectly acceptable to answer [No] provided a proper justification is given (e.g., error bars are not reported because it would be too computationally expensive” or “we were unable to find the license for the dataset we used”). In general, answering [No] or [N/A] is not grounds for rejection. While the questions are phrased in a binary way, we acknowledge that the true answer is often more nuanced, so please just use your best judgment and write a justification to elaborate. All supporting evidence can appear either in the main paper or the supplemental material, provided in appendix. If you answer [Yes] to a question, in the justification please point to the section(s) where related material for the question can be found.

IMPORTANT, please:

- **Delete this instruction block, but keep the section heading “NeurIPS Paper Checklist”.**
- **Keep the checklist subsection headings, questions/answers and guidelines below.**
- **Do not modify the questions and only use the provided macros for your answers.**

1. Claims

Question: Do the main claims made in the abstract and introduction accurately reflect the paper’s contributions and scope?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the abstract and introduction do not include the claims made in the paper.
- The abstract and/or introduction should clearly state the claims made, including the contributions made in the paper and important assumptions and limitations. A [No] or [N/A] answer to this question will not be perceived well by the reviewers.
- The claims made should match theoretical and experimental results, and reflect how much the results can be expected to generalize to other settings.
- It is fine to include aspirational goals as motivation as long as it is clear that these goals are not attained by the paper.

2. Limitations

Question: Does the paper discuss the limitations of the work performed by the authors?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the paper has no limitation while the answer [No] means that the paper has limitations, but those are not discussed in the paper.
- The authors are encouraged to create a separate “Limitations” section in their paper.
- The paper should point out any strong assumptions and how robust the results are to violations of these assumptions (e.g., independence assumptions, noiseless settings, model well-specification, asymptotic approximations only holding locally). The authors should reflect on how these assumptions might be violated in practice and what the implications would be.
- The authors should reflect on the scope of the claims made, e.g., if the approach was only tested on a few datasets or with a few runs. In general, empirical results often depend on implicit assumptions, which should be articulated.
- The authors should reflect on the factors that influence the performance of the approach. For example, a facial recognition algorithm may perform poorly when image resolution is low or images are taken in low lighting. Or a speech-to-text system might not be used reliably to provide closed captions for online lectures because it fails to handle technical jargon.
- The authors should discuss the computational efficiency of the proposed algorithms and how they scale with dataset size.
- If applicable, the authors should discuss possible limitations of their approach to address problems of privacy and fairness.
- While the authors might fear that complete honesty about limitations might be used by reviewers as grounds for rejection, a worse outcome might be that reviewers discover limitations that aren’t acknowledged in the paper. The authors should use their best judgment and recognize that individual actions in favor of transparency play an important role in developing norms that preserve the integrity of the community. Reviewers will be specifically instructed to not penalize honesty concerning limitations.

3. Theory assumptions and proofs

Question: For each theoretical result, does the paper provide the full set of assumptions and a complete (and correct) proof?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the paper does not include theoretical results.
- All the theorems, formulas, and proofs in the paper should be numbered and cross-referenced.
- All assumptions should be clearly stated or referenced in the statement of any theorems.
- The proofs can either appear in the main paper or the supplemental material, but if they appear in the supplemental material, the authors are encouraged to provide a short proof sketch to provide intuition.
- Inversely, any informal proof provided in the core of the paper should be complemented by formal proofs provided in appendix or supplemental material.
- Theorems and Lemmas that the proof relies upon should be properly referenced.

4. Experimental result reproducibility

Question: Does the paper fully disclose all the information needed to reproduce the main experimental results of the paper to the extent that it affects the main claims and/or conclusions of the paper (regardless of whether the code and data are provided or not)?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the paper does not include experiments.

- If the paper includes experiments, a [No] answer to this question will not be perceived well by the reviewers: Making the paper reproducible is important, regardless of whether the code and data are provided or not.
- If the contribution is a dataset and/or model, the authors should describe the steps taken to make their results reproducible or verifiable.
- Depending on the contribution, reproducibility can be accomplished in various ways. For example, if the contribution is a novel architecture, describing the architecture fully might suffice, or if the contribution is a specific model and empirical evaluation, it may be necessary to either make it possible for others to replicate the model with the same dataset, or provide access to the model. In general, releasing code and data is often one good way to accomplish this, but reproducibility can also be provided via detailed instructions for how to replicate the results, access to a hosted model (e.g., in the case of a large language model), releasing of a model checkpoint, or other means that are appropriate to the research performed.
- While NeurIPS does not require releasing code, the conference does require all submissions to provide some reasonable avenue for reproducibility, which may depend on the nature of the contribution. For example
 - (a) If the contribution is primarily a new algorithm, the paper should make it clear how to reproduce that algorithm.
 - (b) If the contribution is primarily a new model architecture, the paper should describe the architecture clearly and fully.
 - (c) If the contribution is a new model (e.g., a large language model), then there should either be a way to access this model for reproducing the results or a way to reproduce the model (e.g., with an open-source dataset or instructions for how to construct the dataset).
 - (d) We recognize that reproducibility may be tricky in some cases, in which case authors are welcome to describe the particular way they provide for reproducibility. In the case of closed-source models, it may be that access to the model is limited in some way (e.g., to registered users), but it should be possible for other researchers to have some path to reproducing or verifying the results.

5. Open access to data and code

Question: Does the paper provide open access to the data and code, with sufficient instructions to faithfully reproduce the main experimental results, as described in supplemental material?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that paper does not include experiments requiring code.
- Please see the NeurIPS code and data submission guidelines (<https://neurips.cc/public/guides/CodeSubmissionPolicy>) for more details.
- While we encourage the release of code and data, we understand that this might not be possible, so [No] is an acceptable answer. Papers cannot be rejected simply for not including code, unless this is central to the contribution (e.g., for a new open-source benchmark).
- The instructions should contain the exact command and environment needed to run to reproduce the results. See the NeurIPS code and data submission guidelines (<https://neurips.cc/public/guides/CodeSubmissionPolicy>) for more details.
- The authors should provide instructions on data access and preparation, including how to access the raw data, preprocessed data, intermediate data, and generated data, etc.
- The authors should provide scripts to reproduce all experimental results for the new proposed method and baselines. If only a subset of experiments are reproducible, they should state which ones are omitted from the script and why.
- At submission time, to preserve anonymity, the authors should release anonymized versions (if applicable).

- Providing as much information as possible in supplemental material (appended to the paper) is recommended, but including URLs to data and code is permitted.

6. Experimental setting/details

Question: Does the paper specify all the training and test details (e.g., data splits, hyperparameters, how they were chosen, type of optimizer) necessary to understand the results?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer [N/A] means that the paper does not include experiments.
- The experimental setting should be presented in the core of the paper to a level of detail that is necessary to appreciate the results and make sense of them.
- The full details can be provided either with the code, in appendix, or as supplemental material.

7. Experiment statistical significance

Question: Does the paper report error bars suitably and correctly defined or other appropriate information about the statistical significance of the experiments?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer [N/A] means that the paper does not include experiments.
- The authors should answer **[Yes]** if the results are accompanied by error bars, confidence intervals, or statistical significance tests, at least for the experiments that support the main claims of the paper.
- The factors of variability that the error bars are capturing should be clearly stated (for example, train/test split, initialization, random drawing of some parameter, or overall run with given experimental conditions).
- The method for calculating the error bars should be explained (closed form formula, call to a library function, bootstrap, etc.)
- The assumptions made should be given (e.g., Normally distributed errors).
- It should be clear whether the error bar is the standard deviation or the standard error of the mean.
- It is OK to report 1-sigma error bars, but one should state it. The authors should preferably report a 2-sigma error bar than state that they have a 96% CI, if the hypothesis of Normality of errors is not verified.
- For asymmetric distributions, the authors should be careful not to show in tables or figures symmetric error bars that would yield results that are out of range (e.g., negative error rates).
- If error bars are reported in tables or plots, the authors should explain in the text how they were calculated and reference the corresponding figures or tables in the text.

8. Experiments compute resources

Question: For each experiment, does the paper provide sufficient information on the computer resources (type of compute workers, memory, time of execution) needed to reproduce the experiments?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer [N/A] means that the paper does not include experiments.
- The paper should indicate the type of compute workers CPU or GPU, internal cluster, or cloud provider, including relevant memory and storage.
- The paper should provide the amount of compute required for each of the individual experimental runs as well as estimate the total compute.

- 520 • The paper should disclose whether the full research project required more compute
521 than the experiments reported in the paper (e.g., preliminary or failed experiments that
522 didn't make it into the paper).

523 **9. Code of ethics**

524 Question: Does the research conducted in the paper conform, in every respect, with the
525 NeurIPS Code of Ethics <https://neurips.cc/public/EthicsGuidelines>?

526 Answer: **[TODO]**

527 Justification: **[TODO]**

528 Guidelines:

- 529 • The answer [N/A] means that the authors have not reviewed the NeurIPS Code of
530 Ethics.
531 • If the authors answer [No], they should explain the special circumstances that require a
532 deviation from the Code of Ethics.
533 • The authors should make sure to preserve anonymity (e.g., if there is a special consid-
534 eration due to laws or regulations in their jurisdiction).

535 **10. Broader impacts**

536 Question: Does the paper discuss both potential positive societal impacts and negative
537 societal impacts of the work performed?

538 Answer: **[TODO]**

539 Justification: **[TODO]**

540 Guidelines:

- 541 • The answer [N/A] means that there is no societal impact of the work performed.
542 • If the authors answer [N/A] or [No], they should explain why their work has no societal
543 impact or why the paper does not address societal impact.
544 • Examples of negative societal impacts include potential malicious or unintended uses
545 (e.g., disinformation, generating fake profiles, surveillance), fairness considerations
546 (e.g., deployment of technologies that could make decisions that unfairly impact specific
547 groups), privacy considerations, and security considerations.
548 • The conference expects that many papers will be foundational research and not tied
549 to particular applications, let alone deployments. However, if there is a direct path to
550 any negative applications, the authors should point it out. For example, it is legitimate
551 to point out that an improvement in the quality of generative models could be used to
552 generate Deepfakes for disinformation. On the other hand, it is not needed to point out
553 that a generic algorithm for optimizing neural networks could enable people to train
554 models that generate Deepfakes faster.
555 • The authors should consider possible harms that could arise when the technology is
556 being used as intended and functioning correctly, harms that could arise when the
557 technology is being used as intended but gives incorrect results, and harms following
558 from (intentional or unintentional) misuse of the technology.
559 • If there are negative societal impacts, the authors could also discuss possible mitigation
560 strategies (e.g., gated release of models, providing defenses in addition to attacks,
561 mechanisms for monitoring misuse, mechanisms to monitor how a system learns from
562 feedback over time, improving the efficiency and accessibility of ML).

563 **11. Safeguards**

564 Question: Does the paper describe safeguards that have been put in place for responsible
565 release of data or models that have a high risk for misuse (e.g., pre-trained language models,
566 image generators, or scraped datasets)?

567 Answer: **[TODO]**

568 Justification: **[TODO]**

569 Guidelines:

- 570 • The answer [N/A] means that the paper poses no such risks.

- Released models that have a high risk for misuse or dual-use should be released with necessary safeguards to allow for controlled use of the model, for example by requiring that users adhere to usage guidelines or restrictions to access the model or implementing safety filters.
- Datasets that have been scraped from the Internet could pose safety risks. The authors should describe how they avoided releasing unsafe images.
- We recognize that providing effective safeguards is challenging, and many papers do not require this, but we encourage authors to take this into account and make a best faith effort.

12. Licenses for existing assets

Question: Are the creators or original owners of assets (e.g., code, data, models), used in the paper, properly credited and are the license and terms of use explicitly mentioned and properly respected?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer [N/A] means that the paper does not use existing assets.
- The authors should cite the original paper that produced the code package or dataset.
- The authors should state which version of the asset is used and, if possible, include a URL.
- The name of the license (e.g., CC-BY 4.0) should be included for each asset.
- For scraped data from a particular source (e.g., website), the copyright and terms of service of that source should be provided.
- If assets are released, the license, copyright information, and terms of use in the package should be provided. For popular datasets, paperswithcode.com/datasets has curated licenses for some datasets. Their licensing guide can help determine the license of a dataset.
- For existing datasets that are re-packaged, both the original license and the license of the derived asset (if it has changed) should be provided.
- If this information is not available online, the authors are encouraged to reach out to the asset's creators.

13. New assets

Question: Are new assets introduced in the paper well documented and is the documentation provided alongside the assets?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer [N/A] means that the paper does not release new assets.
- Researchers should communicate the details of the dataset/code/model as part of their submissions via structured templates. This includes details about training, license, limitations, etc.
- The paper should discuss whether and how consent was obtained from people whose asset is used.
- At submission time, remember to anonymize your assets (if applicable). You can either create an anonymized URL or include an anonymized zip file.

14. Crowdsourcing and research with human subjects

Question: For crowdsourcing experiments and research with human subjects, does the paper include the full text of instructions given to participants and screenshots, if applicable, as well as details about compensation (if any)?

Answer: **[TODO]**

Justification: **[TODO]**

Guidelines:

- The answer [N/A] means that the paper does not involve crowdsourcing nor research with human subjects.
- Including this information in the supplemental material is fine, but if the main contribution of the paper involves human subjects, then as much detail as possible should be included in the main paper.
- According to the NeurIPS Code of Ethics, workers involved in data collection, curation, or other labor should be paid at least the minimum wage in the country of the data collector.

15. Institutional review board (IRB) approvals or equivalent for research with human subjects

Question: Does the paper describe potential risks incurred by study participants, whether such risks were disclosed to the subjects, and whether Institutional Review Board (IRB) approvals (or an equivalent approval/review based on the requirements of your country or institution) were obtained?

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the paper does not involve crowdsourcing nor research with human subjects.
- Depending on the country in which research is conducted, IRB approval (or equivalent) may be required for any human subjects research. If you obtained IRB approval, you should clearly state this in the paper.
- We recognize that the procedures for this may vary significantly between institutions and locations, and we expect authors to adhere to the NeurIPS Code of Ethics and the guidelines for their institution.
- For initial submissions, do not include any information that would break anonymity (if applicable), such as the institution conducting the review.

16. Declaration of LLM usage

Question: Does the paper describe the usage of LLMs if it is an important, original, or non-standard component of the core methods in this research? Note that if the LLM is used only for writing, editing, or formatting purposes and does *not* impact the core methodology, scientific rigor, or originality of the research, declaration is not required.

Answer: [TODO]

Justification: [TODO]

Guidelines:

- The answer [N/A] means that the core method development in this research does not involve LLMs as any important, original, or non-standard components.
- Please refer to our LLM policy in the NeurIPS handbook for what should or should not be described.